Sonrisas de Cristal

Neuralhub

Problema y Alcance

PROBLEMA

Hoy la bitácora de cada estancia se llena a mano, en papel. Las asistentes toman fotos de los niños con su celular personal y las mandan por WhatsApp, así que quedan en teléfonos particulares, sin control sobre datos de menores.
Además, cada estancia paga su propia plataforma, cerca de $2,900 al mes, y la comunicación con las familias está dispersa.

ALCANCE

Una sola plataforma para toda la Fundación, dividida por estancia y por sala. Es una aplicación Android para cuatro perfiles: Fundación, Dirección, Educadora y Familia, conectada a un backend propio. El proyecto se organizó en 14 requerimientos validados por el socio formador, 7 propuestos por el equipo y 36 historias de usuario en 8 épicas.

REQUERIMIENTOS PRINCIPALES

La educadora registra la asistencia y la bitácora del día (RF-03, RF-04).
La familia ve cómo estuvo su hijo (RF-06) y solo accede a sus propios hijos (RF-07).
Las fotos solo las ven las familias de quienes aparecen, y pueden pedir que se eliminen (RF-09, RF-10).
La dirección sabe quién registró y consultó cada dato (RF-14).

Pruebas y Matriz de Trazabilidad

Identificador	Descripción	Criterio de aceptación	Prueba o evidencia	Resultado	Estado final
RF-03	Registro de hora de entrada, salida y quién recoge a cada niño.	Al cierre del día la sala tiene asistencia completa con horas y quién recogió.	RF03AsistenciaTest (integración, API)	4/4 pruebas aprobadas; día completo sin faltantes ni duplicados	**Cumplido**
RF-04	La educadora registra la bitácora del día de cada niño.	Comida, siesta y notas quedan guardadas y firmadas por quien las capturó.	RF04BitacoraTest (integración, API)	4/4 pruebas aprobadas; solo en niños de su sala	**Cumplido**
RF-06	La familia ve cómo estuvo su hijo durante el día.	Ve la bitácora y la asistencia que registró la educadora.	RF06FamiliaVeElDiaTest (integración, API)	4/4 pruebas aprobadas; ambos tutores ven el mismo día	**Cumplido**
RF-07	Cada familia ve solo a sus hijos.	Verificado que un familiar no accede a otro niño, ni manipulando la app.	RF07FamiliaSoloSusHijosTest (integración, API y unitaria)	4/4 pruebas aprobadas; bloqueado en servidor y en cliente	**Cumplido**
RF-09	Las fotos solo las ven las familias de quienes aparecen.	Una foto con tres niños solo la ven las familias de esos tres.	RF09FotosVisiblesTest (integración, API)	4/4 pruebas aprobadas; otras familias no la ven ni por id	**Cumplido**
RF-10	La familia puede pedir que se elimine una foto de su hijo.	La foto se borra para todos y solo si aparece su hijo.	RF10EliminarFotoTest (integración, API)	4/4 pruebas aprobadas; el borrado queda registrado	**Cumplido**
RF-14	La dirección sabe quién registró y consultó cada dato.	Capturas, consultas de fotos e impresiones quedan con persona y niño.	RF14RegistroActividadTest (integración, API)	4/4 pruebas aprobadas; solo la dirección ve el registro	**Cumplido**

Controles de seguridad implementados

6 capas que protegen la seguridad de los niños

Conexión cifrada

Todo lo que envía la app viaja de manera confidencial nadie en el mismo Wi-Fi puede leerlo.

HTTPS (TLS) por un túnel de Cloudflare, con cabeceras de seguridad como HSTS en cada respuesta

Identidad protegida

Nadie puede ver las contraseñas, ni siquiera nosotros, y las sesiones caducan solas.

Contraseñas con PBKDF2 + salt (210,000 iteraciones); tokens guardados como SHA-256 y cifrados en el teléfono con Android Keystore.

Bloqueo a intrusos

Si alguien intenta adivinar una contraseña, la cuenta se bloquea 15 minutos después de 5 intentos.

Rate limiting por IP y por cuenta (HTTP 429), tomando la IP real del proxy para que no se pueda falsificar.

Cada quien ve lo suyo

Cada persona ve solo lo que le corresponde: una mamá, a sus hijos; una educadora, su sala.

Autorización por rol y por objeto en el servidor en cada petición (prevención de IDOR/BOLA); a los datos ajenos responde 404.

Datos íntegros

Nadie puede alterar ni borrar información con trucos, y las acciones delicadas se revisan dos veces.

Consultas parametrizadas (prepared statements) contra inyección SQL, validación de entrada y bitácora de cada cambio.

Caja fuerte digital

El sistema trabaja encerrado, como una caja fuerte, con lo mínimo necesario y con sus llaves guardadas aparte.

Contenedores Docker sin root, de solo lectura y sin capabilities; secretos en variables de entorno (.env).

Neuralhub

Controles de seguridad implementados

Lo comprobamos atacando nuestro propio sistema

27/27

ataques rechazados

Antes de los parches, el sistema resistía 18 de 26.

Ataque simulado	Respuesta del servidor
Inyección SQL en el inicio de sesión	Rechazada (401)
Token falso, alterado o vencido	Sin acceso (401)
Una familia pide los datos de otro niño	“No existe” (404)
6 contraseñas falsas desde IPs distintas	Cuenta bloqueada (429)
Más de 1000 peticiones por minuto	Bloqueado (429)
Borrar un expediente activo sin la app	Rechazado (409)

27 pruebas automatizadas contra el servidor real · 36/36 en verde · OWASP ZAP en el reporte final

Neuralhub

Neuralhub

Capacidad diferenciadora

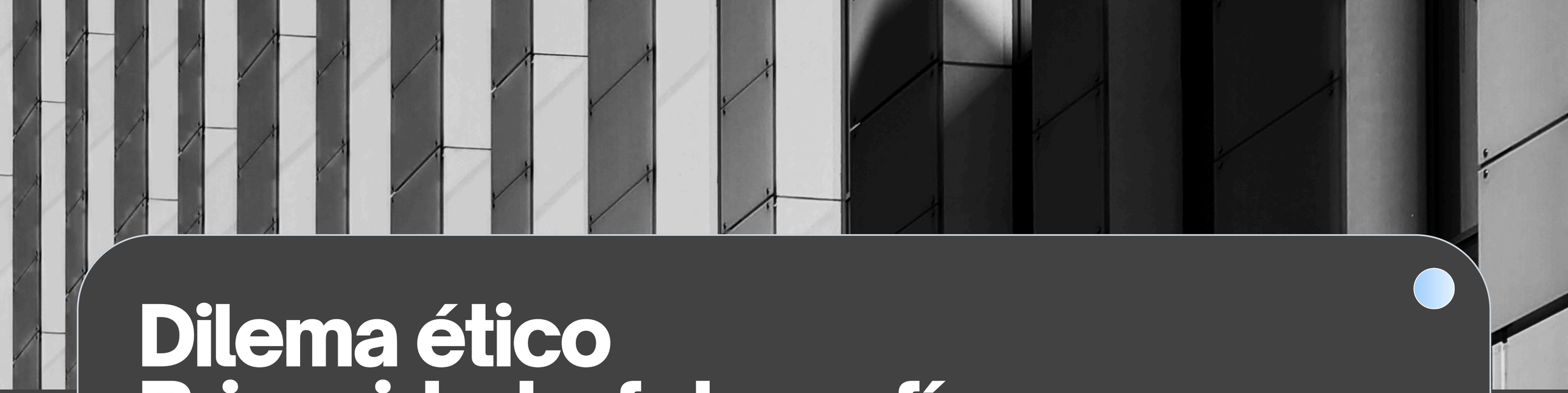
En Sonrisas de Cristal, cada foto de un niño tiene reglas desde que se publica. La Fundación define dos permisos de imagen por separado: actividades internas de la estancia y redes sociales. Una foto solo la ven las familias de los niños que aparecen, y cada familia ve únicamente el nombre de su propio hijo. Además, la familia puede pedir que se borre, y el sistema registra quién capturó y quién consultó cada dato.

2

permisos de imagen por separado: actividades internas y redes sociales

4

perfiles, cada uno ve solo lo que le corresponde



Dilema ético
Privacidad y fotografías

Problema: Compartir fotografías permite a las familias conocer las actividades de sus hijos, pero puede exponer su imagen sin autorización.

Alternativas

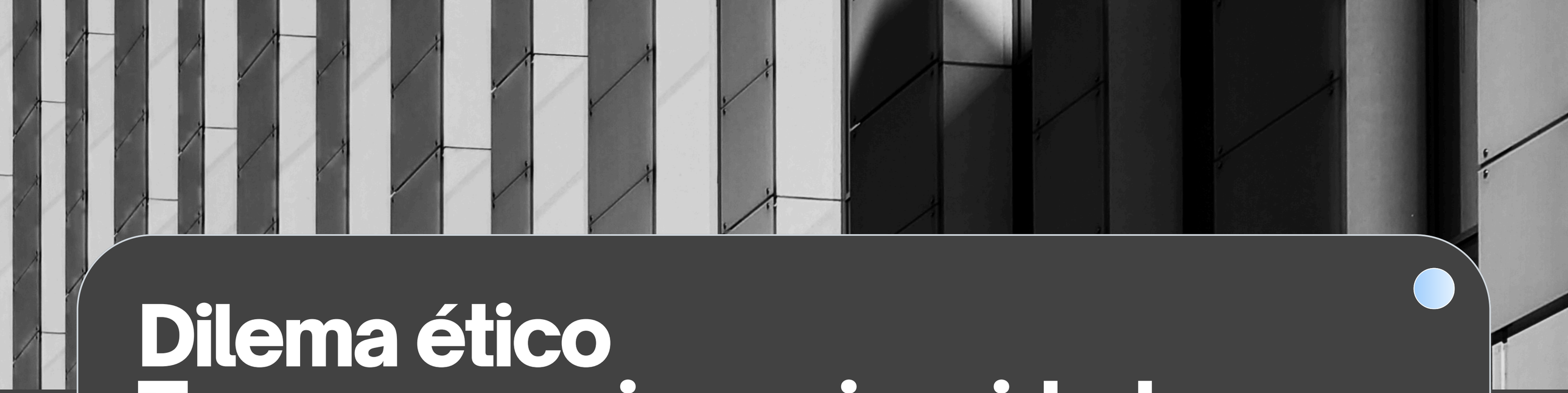
- Compartir todas las fotografías para mantener informadas a las familias.
- Restringir las fotografías según las autorizaciones y los permisos de acceso.

Decisión del equipo

Priorizar la privacidad y protección de los menores.

Relación con la aplicación

- RF-16: Autorización de uso de imagen.
- RF-07: Cada familia solo ve a sus hijos.
- RF-10: Borrar foto.



Dilema ético
Transparencia y privacidad

Problema: Registrar las acciones de los usuarios ayuda a identificar errores, pero también implica manejar información sobre sus actividades.

Alternativas

- Permitir que todos los usuarios consulten los registros.
- Limitar el acceso según el perfil y las responsabilidades de cada usuario.

Decisión del equipo

Mantener la trazabilidad de las acciones y restringir el acceso a la información.

Relación con la aplicación

- RF-14: Registro de quién hizo qué.
- RF-01: Acceso con dos tipos de perfil.
- RF-19: Registro de incidentes.